# Ethical Hacker's Speech, II: Interventi Tecnici e Tavola Rotonda
## Full Day Edition

### SMAU 2002, Area Security, Sabato 26 Ottobre 2002

**Chairman:** Raoul Chiesa, CLUSIT, ITBH

**Relatori:** Fabio Pietrosanti, ITBH - Enrico Zimuel, CLUSIT, ITBH - Andrea Ghirardini, CLUSIT, CISSP - Yvette Agostini, ITBH - Marco Valleri, ITBH - Alberto Ornaghi, ITBH - Igor Falcomatà, ITBH - Stefano Zanero, ITBH, IEEE, ACM.

**Ospiti:** Membri dell'Italian Black Hats Association (ITBH);
**Stefano Pancera**, Giornalista TV (Mediaset-Italia 1/Studio Aperto);
**Marco Tracinà**, (NetManager.it, Portal Manager);
**Stefano Zanero**, Giornalista (Computer World Italia, rubrica fissa "Diario di un Security Manager"), CLUSIT;
**Stefano Chiccarelli** (Autore di Spaghetti Hacker);
**Matteo Curtoni e Maura Parolini** (Traduttori del romanzo "Profondo Blu", The Blue Nowhere, di Jeffrey Deaver, Sonzogno Editore)
**Fabio Ghioni**, Corporate Fraud & Incident Manager (Telecom Italia);
**Dr. Francesco Bricolo**, Psichiatra (MD - Dipartimento delle Dipendenze, ASL Verona);
**On. Marco Cappato**, Parlamentare europeo radicale, Co-Presidente del Partito Radicale Transnazionale (già relatore parlamentare sulla "privacy nelle comunicazioni elettroniche" e sugli "attacchi contro i sistemi d'informazione).

---

**PRIMA SESSIONE**

**Ore 10.00** **Benvenuto ed introduzione ai lavori**
Raoul Chiesa aka Nobody, CLUSIT, ITBH
Fabio Pietrosanti aka Naif, ITBH

**Ore 10.15** **Introduzione alla crittografia ed alla crittoanalisi**
Enrico Zimuel aka Cerino, CLUSIT, ITBH

**Ore 11.45** **Web server ed applicazioni web.**
**Principali problematiche di sicurezza e tipici errori implementativi**
Igor Falcomatà aka Kobaiashi, ITBH

**Ore 12.30** **Ethical hacking, Unethical laws: Dissertazione sulla legislazione antiterrorismo e antipirateria**
Stefano Zanero aka Raistlin, ITBH, IEEE, ACM

**Ore 13.30** **Pausa Pranzo**

***

**SECONDA SESSIONE**

**Ore 14.00** **Introduzione alla sessione pomeridiana**
Raoul Chiesa aka Nobody
Fabio Pietrosanti aka Naif

**Ore 14.15** **Ingegneria Sociale: un'arma sottovalutata**
Andrea "Pila" Ghirardini, CISSP, CLUSIT

**Ore 15.00** **Attacchi Man in the Middle**
Marco Valleri aka Naga, ITBH
Alberto Ornaghi aka Alor, ITBH

**Ore 16.00** **Wireless (in)security @ SMAU**
Fabio Pietrosanti aka Naif, ITBH

**Ore 16.30** **Storia ed Etica Hacker**
Ing. Yvette Agostini aka Vodka, ITBH
Raoul Chiesa aka Nobody, CLUSIT, ITBH

**Ore 17.15** **Tavola Rotonda con Relatori, Ospiti e Pubblico:**
**Sicurezza, Underground, Privacy e Anonimato VS. Professionalità nel Proprio Lavoro**

**Ore 18.00** **Chiusura Lavori**

# Programma Dettagliato degli Interventi Tecnici

## PRIMA SESSIONE

**Ore 09.30** **Benvenuto ed introduzione ai lavori**
Raoul Chiesa aka Nobody, CLUSIT, ITBH
Fabio Pietrosanti aka Naif, ITBH

Presentazione della giornata.
Elenco degli speech sessione mattutina.
Presentazione ITBH, Associazione Italiana Black Hats.

---

**Ore 09.45** **Introduzione alla crittografia ed alla crittoanalisi**
Enrico Zimuel aka Cerino, CLUSIT, ITBH

L'intervento è finalizzato all'introduzione dei concetti fondamentali della crittografia e della possibilità di violare sistemi crittografici con tecniche di crittoanalisi.
Oltre ad un'introduzione teorica verranno forniti esempi pratici su alcune tecniche di attacco su programmi e protocolli crittografici moderni.
In particolare verranno presi in esame alcuni casi classici di attacco sul programma più utilizzato su Internet per l'interscambio di informazioni sensibili, il PGP (Pretty Good Privacy).

L'intervento sarà concluso con alcune riflessioni sulla necessità d'utilizzo di strumenti hardware e software "aperti" di tipo open-source al fine di garantire sicurezza e conseguente privacy attraverso l'uso di tecniche crittografiche nei moderni sistemi informatici e di comunicazione.

Argomenti principali dell'intervento:
Introduzione alla crittografia: Le basi della crittografia. Origini storiche. La crittografia moderna. I cifrari simmetrici. I cifrari asimmetrici. Le funzioni hash one-way e la firma digitale. L'identificazione. L'autenticazione.
Introduzione alla crittoanalisi: Le basi della crittoanalisi. La crittoanalisi statistica. La crittoanalisi linerare. La crittoanalisi differenziale. Tipologie di attacchi: Cipher Text Attack, Known Plain-Text Attack, Chosen Plain-Text Attack, Man-in-the-Middle. Attacchi al protocollo di firma. Alcuni casi reali: un attacco al software PGP con tecniche di crittoanalisi ed alcuni bug.

---

**Ore 11.15** **Web server ed applicazioni web.**
**Principali problematiche di sicurezza e tipici errori implementativi**
Igor Kobaiashi Falcomatà, ITBH

Verranno illustrate le evoluzioni degli attacchi alle applicazioni web e si ragionerà sugli errori più classici connessi al loro sviluppo.

---

**Ore 12.00** **Dissertazione sulla legislazione antiterrorismo e antipirateria**
Stefano "Raistlin" Zanero, ITBH, IEEE, ACM

Se è vero che la ricerca sulla sicurezza informatica passa inderogabilmente attraverso la passione per l'hacking, è difficile giustificare la presenza di clausole contrarie alla ricerca scientifica e al progresso nelle nuove legislazioni antiterrorismo e sul copyright. Dalla DMCA all'AntiTerrorism Act, alla direttiva 2001/29 della comunità europea, commenteremo tutte le iniziative legislative viziate da questo approccio, e numerose testimonianze di ricercatori in tutto il mondo. È prevista una sessione di dibattito.



## SECONDA SESSIONE

**Ore 14.00** **Introduzione alla sessione pomeridiana**
Raoul Chiesa aka Nobody, CLUSIT, ITBH
Fabio Pietrosanti aka Naif, ITBH

Riassunto della sessione mattutina.
Presentazione sessione pomeridiana.
Presentazione ITBH, Associazione Italiana Black Hats.

---

**Ore 14.15** **Ingegneria Sociale: un'arma sottovalutata**
Andrea "Pila" Ghirardini, CISSP, CLUSIT

E' possibile compromettere un sistema informativo senza utilizzare nemmeno un computer: in questo intervento Andrea "Pila" Ghirardini ci spiegherà le metodologie di attacco tramite Social Engineering.

---

**Ore 15.00** **Attacchi Man in the Middle**
Marco Valleri aka Naga, ITBH
Alberto Ornaghi aka Alor, ITBH

Vengono illustrate gran parte delle problematiche relative agli attacchi di tipo "man in the middle".
Questo tipo di attacchi mette l'intruso in condizione di vedere e modificare il traffico tra due (o più) host vittime. Gli attacchi trattati saranno suddivisi in tre grandi categorie: in rete locale, da locale a remoto, e in remoto.

Nello specifico saranno presentati: arp poisoning, dns spoofing, dhcp spoofing, dns poisoning, icmp redirection, route mangling, traffic tunneling.
Per ognuno di questi attacchi verranno descritti i problemi inerenti, analizzati i modi per portarli a termine, indicate le tracce lasciate, proposte alcune contromisure da adottare per prevenirli.

Saranno inoltre presentati alcuni modi di sfruttare questo tipo di attacco, come l'introduzione di "codice maligno" e la "rottura" di alcune delle suite crittografiche più utilizzate.

---

**Ore 16.00** **Wireless (in)security @ SMAU**
Fabio Pietrosanti aka Naif, ITBH

Durante questo intervento verranno presentati i risultati di una sessione di warwalking ( variante "a piedi" del wardriving, la ricerca di reti wireless) effettuata all'interno delle aree espositive di SMAU.
Verranno presentate statistiche sulla presenza di reti secondo lo standard Wi-Fi 802.11, sul loro livello di sicurezza e la relativa locazione.
Warwalking @ SMAU2002 è una iniziativa Blackhats.it

---

**Ore 16.30** **Storia ed Etica Hacker: riflessioni**
Ing. Yvette Agostini aka Vodka, ITBH
Raoul Chiesa aka Nobody, ITBH

Cenni storici sulla cultura hacker, per inquadrare correttamente il concetto di etica.
Dal jargon file al mondo accademico e viceversa: parallelo tra ricerca scientifica, accademica e modalità di lavoro hacker.
Cultura hacker e mondo del lavoro: security/hacking is a state of mind.
Disclosure vs undisclosure: due approcci eticamente differenti allo scottante tema della sicurezza informatica.

---

**Ore 17.15** **Tavola Rotonda con Relatori, Ospiti e Pubblico: Sicurezza, Underground, Privacy e Anonimato VS. Professionalità nel Proprio Lavoro.**

# CV dei Relatori

- **Andrea Ghirardini aka Pila**
  Andrea "Pila" Ghirardini, dopo dieci anni di esperienza "ufficiale", divisa tra società informatiche e di telecomunicazioni, lavora ora con la sua società come consulente nei settori dell'Information Security, Computer Forensics e Indagini Informatiche.
  Collabora attivamente con le Forze dell'Ordine per indagini di particolare rilevanza tecnica.

- **Enrico Zimuel aka Cerin0**
  Enrico Zimuel è consulente informatico su temi di sicurezza informatica, crittografia e crittoanalisi. Collabora da anni con diverse riviste di informatica in Italia ed ha scritto un libro di crittografia "Segreti, Spie e Codici Cifrati" edito da Apogeo.
  Ha tenuto numerosi corsi e conferenze sul tema della crittografia e della crittoanalisi in diverse Università italiane e per numerose società operanti nel settore dell'IT-Security.
  Collaboratore del progetto open source GnuPg (www.gnupg.org) gestisce su Internet un sito interamente dedicato al mondo della crittologia, www.enricozimuel.net. Il suo interesse di ricerca è legato soprattutto allo studio degli algoritmi crittografici e delle tecniche matematiche.
  Per avere maggiori informazioni sul suo curriculum vitae: www.enricozimuel.net/curriculum.htm.

- **Marco Valleri e Alberto Ornaghi (Naga ed Alor)**
  **Marco Valleri** (NaGA), laureando in informatica presso l'Universita' di Milano, lavora per Intesis gruppo Finmatica come Pen-Tester. Creatore del progetto "ettercap", partecipa all'iniziativa no-profit blackhats.it.
  **Alberto Ornaghi** (ALoR), in tesi presso l'Universita' di Milano, dove sviluppa un protocollo alternativo ad ARP che previene gli attacchi "arp-spoofing".
  Creatore del progetto "ettercap", partecipa all'iniziativa no-profit blackhats.it.
  Entrambi sviluppatori in ambiente Free Software e particolarmente focalizzati sulle problematiche security related, sono membri di ITBH dal luglio 2002.

- **Ivette Agostini aka Vodka**
  Yvette Agostini è laureata in ingegneria, sistemista UNIX, segue con passione il tema della diffusione della cultura della sicurezza nelle aziende.
  Collabora saltuariamente con week.it (Mondadori) e scrive articoli divulgativi su temi di informatica per siti femminili (www.dols.net).

- **Raoul Chiesa aka Nobody**
  Raoul Chiesa è uno tra i primi ethical hacker italiani; Fondatore della Divisione Sicurezza Dati in @ Mediaservice.net, è Membro del Comitato Direttivo del CLUSIT (Associazione Italiana per la Sicurezza Informatica) e Socio Fondatore.
  Si occupa da anni di sicurezza informatica ad alto livello insieme ad un selezionato team di tecnici ed esperti, con collaborazioni internazionali.
  E' tra i fondatori di ITBH.

- **Fabio Pietrosanti aka Naif**
  Network Security Manager della I.NET SpA (gruppo BT Ignite), appena ventiduenne, si occupa di security professionalmente dal '98. Il suo attuale lavoro è di ricerca e implementazione di soluzioni di security, Penetration Testing, Forensic Analisys, Network Planning.
  Scrive articoli tecnici per alcune riviste di settore e partecipa a numerosi eventi sulla sicurezza informatica sia ufficiali che underground, come relatore e spettatore.
  Con il nome naif vive quotidianamente l'underground digitale italiano, da dove provengono tutti i suoi skill tecnici. E' tra i fondatori di ITBH.

- **Igor Falcomatà aka Kobaiashi**
  Nato a Bolzano nel settembre del 1974, studi scientifici, si interessa fin dall'infanzia di informatica e programmazione. Durante le prime attività professionali, si occupa dello sviluppo di applicazioni di gestione database ed archivi dati. In seguito si occupa di applicazioni multimediali e gestione di sistemi.
  Da sempre appassionato di telematica, fin dai tempi delle prime BBS si occupa di problematiche legate ai virus ed agli attacchi informatici. Dal 1997 si occupa professionalmente di sicurezza informatica, prima come consulente freelance; partecipa poi alla fondazione di Infosec, società specializzata nella fornitura di servizi e consulenza per la sicurezza informatica.
  Attualmente ricopre l'incarico di IT Security Manager e le sue principali aree di attivita' riguardano tutti gli aspetti della sicurezza informatica e delle telecomunicazioni, in particolar modo Penetration Test e Security Assessment, formazione, ricerca e sviluppo; per conto di importanti clienti pubblici e privati (banche, carrier, etc.).
  E' tra i membri fondatori del progetto sikurezza.org (importante mailing list dedicata alla sicurezza informatica) e socio di ITBH.

- **Stefano Zanero aka Raistlin**
  Stefano Zanero è laureando in Ingegneria Informatica presso il Politecnico di Milano, con una tesi sullo sviluppo di un Intrusion Detection System basato su reti neurali. Tra i suoi interessi di ricerca figurano inoltre la sicurezza delle smart card e la "behavior engineering". È socio dell'IEEE e della ACM. È Information Security Analyst per ComputerWorld Italia, e in tale veste ha partecipato a convegni nazionali ed internazionali. Ha svolto e svolge attività private di consulenza sulle tematiche della sicurezza e dell'integrazione di rete.